



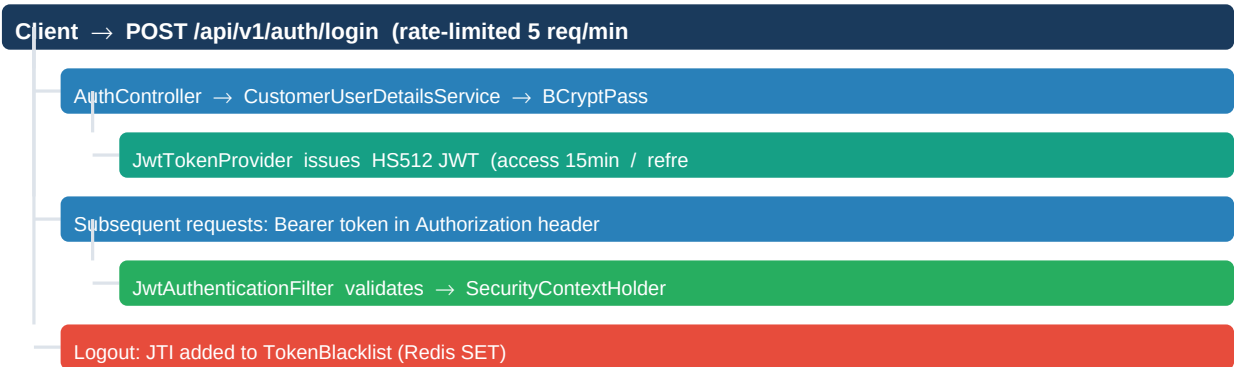
Security

TLS · JWT · OAuth2 · OIDC · SAML2 · OWASP · RBAC

Overview

Full security stack: TLS termination, JWT auth, OAuth2/OIDC resource server, optional SAML2 SSO, OWASP Top 10 mitigations, AES-256-GCM at-rest encryption, and RBAC+ABAC authorization.

Authentication Flow



OAuth2 / OIDC / SAML2 Summary

Protocol	Class	Config
OAuth2 Resource Server	spring-security-oauth2-resource-server	jwt.jwk-set-uri → Keycloak JWKS endpoint
OIDC	OidcUserService	Extracts shopverse_roles from ID token claims
Authorization Code Flow	OAuth2LoginConfig	spring.security.oauth2.client (admin UI)
SAML2 (optional)	Saml2Config	@ConditionalOnProperty; RelyingPartyRegistrationRepository

OWASP Top 10 Mitigations

Risk	ShopVerse Mitigation	Class
A01 Broken Access Control	@PreAuthorize / @PostAuthorize; Permissions	SecurityConfig
A02 Crypto Failures	AES-256-GCM for paymentToken; BCrypt(12) for passwords	AES for paymentToken; BCrypt for passwords
A03 Injection	JPQL named params; PreparedStatement; String concatenation	QueryRepository
A05 Security Misconfigurations	SecurityHeadersConfig; CSRF, CORS	SecurityConfig
A07 Auth Failures	JWT blacklist; refresh token SHA256 hash	TokenBlacklist
A09 Logging Failures	Structured JSON logging with traceId, customerId	LogbackSpring.xml

Authorization Model

Model	Annotation / Class	Example
RBAC	@PreAuthorize("hasRole('ADMIN')")	ProductController.delete()
ABAC	@PreAuthorize("#order.customerId == authentication.principal.id")	OrderController.getOrder()

Model	Annotation / Class	Example
Fine-grained	PermissionEvaluator.hasPermission(auth, obj, role)	Object checks

Security Headers (SecurityHeadersConfig)

Content-Security-Policy: default-src 'self'
X-Frame-Options: DENY
X-Content-Type-Options: nosniff
Strict-Transport-Security: max-age=31536000